Phantom's Footprints

Tags: ⚙️ Forensics · Hard · VICEROY series **Points:** 400 **Type:** Auto-checked

Description

Scenario Constraint 1: Reconstruct the intrusion.

SENTINEL-01, a cUAS sensor node tied to our inherited satellite ground segment, is compromised but must remain online. The Phantom actor bypassed the ground-segment relay and reached the operator console. We need to know exactly what they did, what they downloaded, and how they maintained access before we can confidently neutralize them.

Incident Response has extracted a raw disk image of the compromised file system. It contains over 5,000 lines of normal system noise to simulate a live environment.

Setup Instructions

First, open your terminal in the exact folder where you downloaded `sentinel_01.img`. To analyze the raw disk image on your Kali machine, you must mount it as a local loop device. Copy and paste the following commands into your terminal:

```
mkdir -p ~/Desktop/sentinel_drive
sudo mount -o loop sentinel_01.img ~/Desktop/sentinel_drive
cd ~/Desktop/sentinel_drive
```

Basic Linux Navigation

If you are new to investigating via the terminal, here are a few essential commands to help you move around the mounted drive:

- `cd <folder>` : Change into a specific directory (e.g., `cd var/log`).
- `cd ..` : Move up one directory level.
- `ls -la` : List all files and folders, including hidden ones.
- `cat <file>` : Print the entire contents of a text file to your screen.
- `cat <file> | grep "keyword"` : Search inside a file for a specific word or phrase by piping the output.

Your Mission

Navigate the mounted file system and interrogate the logs (`var/log/auth.log`, `var/log/syslog`, and `root/.bash_history`) to answer these six questions:

1. What is the external IP address the Phantom actor used to initially log in?
2. What exact command did the attacker use to wipe their terminal activity?
3. What native Linux service did the attacker name their malicious payload after?
4. What is the absolute path to the hidden memory-backed directory where the payload was stashed?
5. What is the un-obfuscated IPv4 address of the C2 server?
6. What is the exact timestamp of the kernel segfault?

> **Admin / Organizer Answer Key**
>
> **1. 185.220.101.46**
>
> **2. history -c**
>
> **3. systemd-update**
>
> **4. /dev/shm/.cache**
>
> **5. 192.168.100.55**
>
> **6. 14:05:33**

Cleanup Instructions

When you have successfully reconstructed the intrusion, unmount the image to clean up your workspace and prevent file corruption.

```
cd ~
sudo umount ~/Desktop/sentinel_drive
rmdir ~/Desktop/sentinel_drive
```

Hints

- **Hint 1:** The `.bash_history` file is packed with fake commands to throw you off! To find what the attacker actually did, try piping the file into `grep` (e.g., `cat .bash_history | grep "wget"`) to search for suspicious keywords like `base64`, `wget`, or `history`.
- **Hint 2:** Did you find a long, weird jumble of characters next to a `base64 -d` command? That's encoded text! You can decode it right in your terminal by typing `echo "THE_WEIRD_TEXT_HERE" | base64 -d`. Once you reveal the hidden command, you'll see the attacker obfuscated their C2 server IP address as a giant decimal number. You can easily convert it back to a standard IPv4 address by running `ping -c 1 <decimal_number>` in your terminal.
- **Hint 3:** To find the payload's disguise and crash time, search the `syslog` for the word `segfault`. You may need to use `cat syslog | grep -B 2 -A 2 "segfault"` to read the lines